

SIMATS ENGINEERING ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01 Total Marks:100

Annexure A VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

*I M Kavya 192472370 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: Kavya

S.No .	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Mark s
1	Incident Background and Technical Understanding (20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities (20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	

		user awareness.				
5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

1. Introduction

The TJX Companies suffered a major payment-card data breach between 2005 and 2007. Attackers gained unauthorized access to the retail network through weaknesses in the wireless network. The incident highlighted the risks associated with obsolete wireless encryption, weak authentication, inadequate network segmentation, insufficient monitoring, and poor protection of payment-card information.

This vulnerability assessment examines the major security weaknesses involved in the incident and recommends modern controls such as WPA2/WPA3, enterprise authentication, rogue-access-point detection, network segmentation, continuous monitoring, and PCI DSS compliance.

2. Objectives

The main objectives of this vulnerability assessment are:

1. To examine weaknesses in wireless encryption.
2. To analyze authentication weaknesses.
3. To evaluate network segmentation.

4. To assess wireless and network monitoring.
5. To examine protection of payment-card data.
6. To recommend WPA2/WPA3 and enterprise authentication.
7. To recommend rogue-access-point detection.
8. To identify relevant PCI DSS security controls.
9. To demonstrate safe security-assessment commands in an authorized lab.

3. Vulnerability Assessment Methodology

The assessment follows these stages:

Phase	Activity
1	Information gathering
2	Wireless security assessment
3	Authentication assessment
4	Network segmentation assessment
5	Monitoring assessment
6	Payment-data protection assessment
7	Risk analysis
8	Security recommendations

The technical commands provided below are intended only for systems and wireless networks for which the tester has explicit authorization.

4. Wireless Encryption Assessment

Vulnerability

One of the major weaknesses associated with the TJX incident was the use of **WEP (Wired Equivalent Privacy)**.

WEP is an obsolete wireless security protocol. Its cryptographic design contains weaknesses that can allow an attacker to recover the wireless key after collecting sufficient wireless traffic.

The transition from WEP to stronger security also created an exposure window.

Risk

Factor	Assessment
Encryption	WEP – obsolete
Confidentiality	Low
Attack resistance	Low
Data exposure	High
Overall risk	Critical

Recommended Control

Organizations should completely eliminate WEP and use:

- WPA2-Enterprise with AES/CCMP where WPA3 is not available.
- WPA3-Enterprise where supported.
- Strong authentication credentials.
- Protected management frames where supported.
- Separate wireless networks for employees, guests, and sensitive systems.

5. Wireless Security Assessment – Kali Linux

For an authorized laboratory wireless network, identify the wireless interface:

```
iwconfig
```

or:

```
ip link
```

Check available wireless interfaces:

```
iw dev
```

Example output may show:

Interface wlan0

type managed

To view nearby wireless networks in an authorized lab:

```
sudo nmcli device wifi list
```

This can provide information such as:

- SSID
- BSSID

- Channel
- Signal strength
- Security type

What to look for

A vulnerability assessment should flag:

WEP

Open

WPA/WPA2 with weak configuration

Weak authentication

Unknown access points

Duplicate/suspicious SSIDs

WEP should be classified as a **critical/high-risk finding** because it does not provide adequate protection for sensitive corporate information.

6. Authentication Assessment

Vulnerability

Wireless access should not rely on a shared password for a sensitive corporate network.

A stronger architecture is **WPA2-Enterprise or WPA3-Enterprise** using **802.1X authentication**.

Recommended Controls

- WPA2-Enterprise or WPA3-Enterprise.
- 802.1X authentication.
- RADIUS authentication.
- Unique credentials for employees.
- Strong password policies.
- Certificate-based authentication such as EAP-TLS where practical.
- Immediate account revocation when employees leave.
- Multi-factor authentication for administrative access.

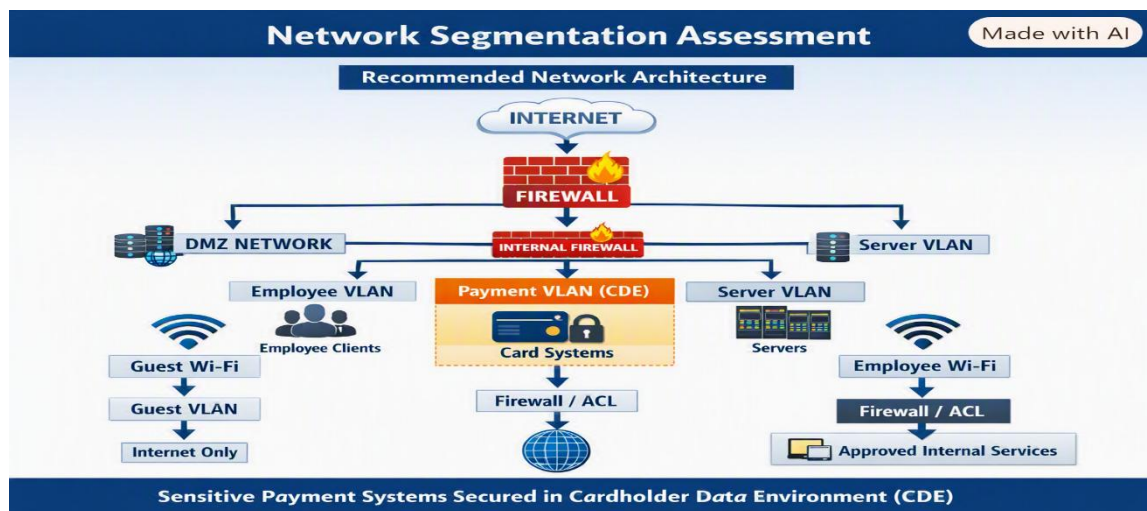
7. Network Segmentation Assessment

Vulnerability

A wireless compromise becomes much more dangerous if the wireless network has unrestricted access to internal systems.

Sensitive payment systems should not be directly reachable from ordinary wireless clients.

Recommended Network Architecture



Payment-card systems should be placed inside a restricted **Cardholder Data Environment (CDE)**.

8. Network Segmentation Testing – Kali Linux

In an authorized lab, identify the local network configuration:

ip addr

```
(kavya@kavya)-[~]
$ sudo apt install iw arp-scan -y
iw is already the newest version (6.17-1).
iw set to manually installed.
arp-scan is already the newest version (1.10.0-2+b1).
arp-scan set to manually installed.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0

(kavya@kavya)-[~]
$ iw dev

(kavya@kavya)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:91:91:db brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 77437sec preferred_lft 77437sec
    inet6 fd17:625c:f037:2:4a3b:b54e:30a8:f7a3/64 scope global temporary dynamic
        valid_lft 86278sec preferred_lft 14278sec
    inet6 fd17:625c:f037:2:a00:27ff:fe91:91db/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86278sec preferred_lft 14278sec
    inet6 fe80::a00:27ff:fe91:91db/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

View routing information:

ip route

```
(kavya@kavya)-[~]
$ ip route
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100

(kavya@kavya)-[~]
$ iw dev
```

Identify reachable devices in your authorized subnet:

sudo nmap -sn 10.0.2.15/24

```
(kavya@kavya)-[~]
$ sudo nmap -sn 10.0.2.15/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 10:41 +0530
Nmap scan report for 10.0.2.2
Host is up (0.00069s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.3
Host is up (0.00097s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.15
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 8.64 seconds
```

Replace the subnet with the subnet assigned to your laboratory.

For a specific authorized host:

nmap -sV 10.0.2.15

```
(kavya@kavya)-[~]
$ sudo nmap -sS 10.0.2.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 10:42 +0530
Stats: 0:00:44 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 20.50% done; ETC: 10:46 (0:02:43 remaining)
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 35.00% done; ETC: 10:46 (0:02:12 remaining)
Stats: 0:01:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 49.00% done; ETC: 10:46 (0:01:44 remaining)
Stats: 0:03:10 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 93.00% done; ETC: 10:46 (0:00:14 remaining)
Nmap scan report for 10.0.2.15
Host is up.
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 204.68 seconds
```

```
(kavya@kavya)-[~]
$ sudo nmap -sS -p 22,80,443,445,3389 10.0.2.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 10:54 +0530
Nmap scan report for 10.0.2.15
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh
80/tcp    filtered  http
443/tcp   filtered  https
445/tcp   filtered  microsoft-ds
3389/tcp  filtered  ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 5.11 seconds
```

```
(kavya@kavya)-[~]
$ sudo nmap -sV -p 22,80,443,445,3389 10.0.2.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 10:56 +0530
Nmap scan report for 10.0.2.15
Host is up.

PORT      STATE      SERVICE      VERSION
22/tcp    filtered  ssh
80/tcp    filtered  http
443/tcp   filtered  https
445/tcp   filtered  microsoft-ds
3389/tcp  filtered  ms-wbt-server

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.74 seconds
```

```
(kavya@kavya)-[~]
$ sudo nmap -o 10.0.2.15
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 10:57 +0530
Stats: 0:01:12 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 34.50% done; ETC: 11:00 (0:02:13 remaining)
Nmap scan report for 10.0.2.15
Host is up (0.017s latency).
All 1000 scanned ports on 10.0.2.15 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 207.40 seconds
```


The purpose is to identify whether unnecessary services are accessible.

Check connectivity:

ping 10.0.2.15

```
(kavya@kavya)-[~]
$ ping 10.0.2.15
PING 10.0.2.15 (10.0.2.15) 56(84) bytes of data:
64 bytes from 10.0.2.15: icmp_seq=1 ttl=64 time=1.27 ms
64 bytes from 10.0.2.15: icmp_seq=2 ttl=64 time=0.058 ms
64 bytes from 10.0.2.15: icmp_seq=3 ttl=64 time=0.065 ms
64 bytes from 10.0.2.15: icmp_seq=4 ttl=64 time=0.068 ms
64 bytes from 10.0.2.15: icmp_seq=5 ttl=64 time=0.077 ms
64 bytes from 10.0.2.15: icmp_seq=6 ttl=64 time=0.045 ms
64 bytes from 10.0.2.15: icmp_seq=7 ttl=64 time=0.063 ms
64 bytes from 10.0.2.15: icmp_seq=8 ttl=64 time=0.080 ms
64 bytes from 10.0.2.15: icmp_seq=9 ttl=64 time=0.152 ms
64 bytes from 10.0.2.15: icmp_seq=10 ttl=64 time=0.064 ms
64 bytes from 10.0.2.15: icmp_seq=11 ttl=64 time=0.074 ms
64 bytes from 10.0.2.15: icmp_seq=12 ttl=64 time=0.074 ms
64 bytes from 10.0.2.15: icmp_seq=13 ttl=64 time=0.080 ms
64 bytes from 10.0.2.15: icmp_seq=14 ttl=64 time=0.157 ms
64 bytes from 10.0.2.15: icmp_seq=15 ttl=64 time=0.082 ms
64 bytes from 10.0.2.15: icmp_seq=16 ttl=64 time=0.068 ms
64 bytes from 10.0.2.15: icmp_seq=17 ttl=64 time=0.071 ms
64 bytes from 10.0.2.15: icmp_seq=18 ttl=64 time=0.079 ms
64 bytes from 10.0.2.15: icmp_seq=19 ttl=64 time=0.093 ms
64 bytes from 10.0.2.15: icmp_seq=20 ttl=64 time=0.050 ms
64 bytes from 10.0.2.15: icmp_seq=21 ttl=64 time=0.066 ms
64 bytes from 10.0.2.15: icmp_seq=22 ttl=64 time=0.056 ms
64 bytes from 10.0.2.15: icmp_seq=23 ttl=64 time=0.066 ms
64 bytes from 10.0.2.15: icmp_seq=24 ttl=64 time=0.062 ms
64 bytes from 10.0.2.15: icmp_seq=25 ttl=64 time=0.148 ms
64 bytes from 10.0.2.15: icmp_seq=26 ttl=64 time=0.089 ms
```

Assessment

If an employee wireless client can directly reach payment servers or database servers without appropriate firewall restrictions, this represents a significant segmentation weakness.

9. Monitoring Assessment

Vulnerability

Insufficient monitoring can allow attackers to remain inside a network without being detected quickly.

Wireless environments should be monitored for:

- Unauthorized access points.
- Rogue access points.
- Evil-twin networks.
- Unknown wireless clients.
- Unusual authentication attempts.
- Abnormal network traffic.
- Unauthorized connections to sensitive systems.

Recommended Controls

Organizations should deploy:

- Wireless Intrusion Detection Systems (WIDS).
- Wireless Intrusion Prevention Systems (WIPS).
- SIEM.
- Centralized logging.
- Network IDS/IPS.
- Endpoint monitoring.
- Continuous alerting.

10. Wireless Monitoring Commands

In an authorized wireless lab, monitor the wireless interface:

```
iw dev wlan0 link
```

Check wireless interface information:

```
iw dev wlan0 info
```

Monitor network traffic on an authorized interface:

```
sudo tcpdump -i wlan0
```

Capture traffic to a file for later analysis:

```
sudo tcpdump -i wlan0 -w wireless_capture.pcap
```

The capture can then be analyzed using Wireshark.

For network service monitoring:

```
sudo ss -tulnp
```

This displays listening TCP/UDP services on the local system.

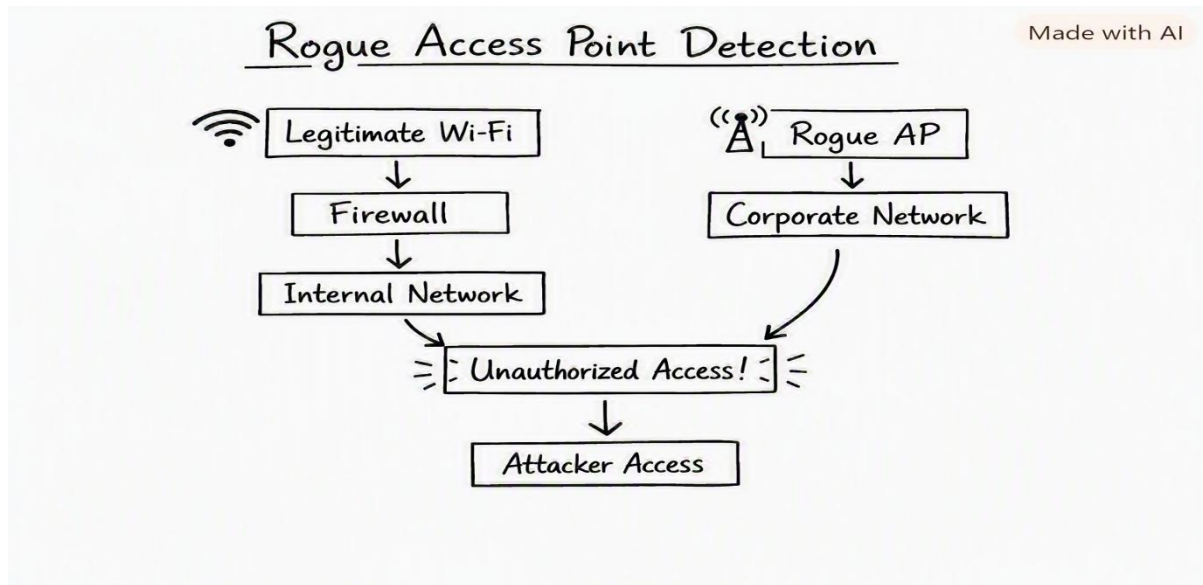
11. Rogue Access Point Detection

Vulnerability

An unauthorized access point connected to the corporate environment can bypass normal security controls.

For example:

This can provide attackers with unauthorized network access.



Recommended Controls

1. Maintain an inventory of authorized access points.
2. Continuously scan for unknown BSSIDs.
3. Compare detected APs with the approved inventory.
4. Investigate duplicate corporate SSIDs.
5. Use WIDS/WIPS.
6. Alert security administrators when an unauthorized AP is detected.
7. Physically remove unauthorized devices.

12. Payment-Data Protection

The compromise of payment-card information represents a serious security risk.

Payment data should be protected through:

- Encryption in transit.
- Encryption at rest where appropriate.
- Tokenization.
- Strong access control.
- Network segmentation.
- Logging and monitoring.
- Vulnerability management.
- Secure configuration.

- Restricted administrative access.

Sensitive authentication data should not be retained unnecessarily.

13. PCI DSS Controls

PCI DSS provides security requirements for environments that store, process, or transmit payment-card data.

Important controls include:

PCI DSS Security Area	Recommended Control
Network security	Firewalls and secure network architecture
Secure configuration	Remove unnecessary services
Stored card data	Minimize and protect stored data
Encryption	Encrypt sensitive data during transmission
Anti-malware	Deploy appropriate malware protection
Secure development	Follow secure development practices
Access control	Restrict access based on business need
Authentication	Unique IDs and strong authentication
Physical security	Restrict physical access
Logging	Monitor and retain security logs
Vulnerability management	Regular vulnerability scanning
Testing	Regular penetration/security testing

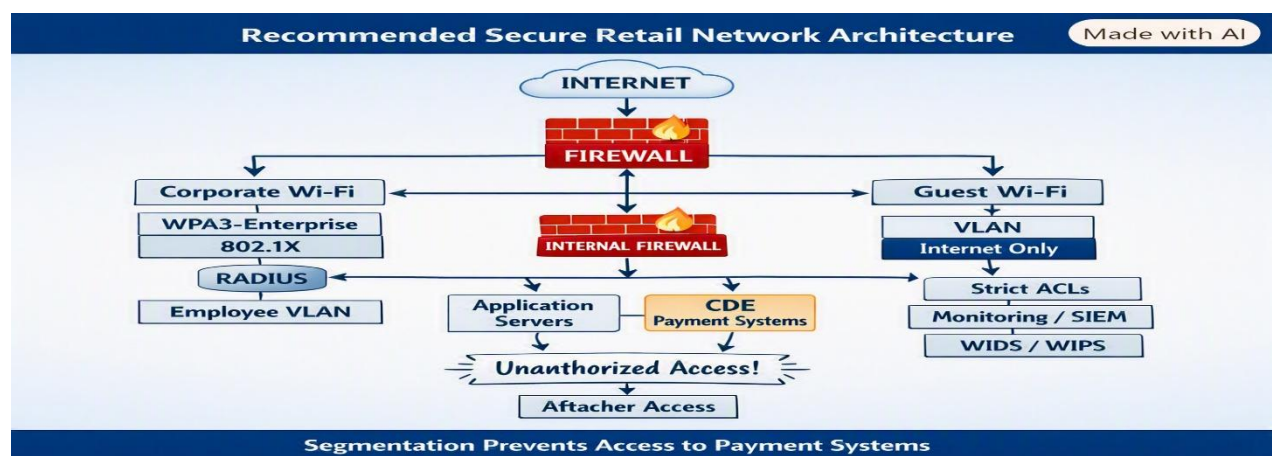
14. Vulnerability Risk Assessment

Vulnerability	Severity	Impact	Recommended Mitigation
WEP encryption	Critical	Wireless traffic could be compromised	WPA2/WPA3
Weak wireless authentication	High	Unauthorized access	WPA2/3-Enterprise + 802.1X
Poor network	Critical	Attacker	VLANs +

segmentation		s could move toward sensitive systems	ACLs + firewalls
Insufficient monitoring	High	Delayed detection	WIDS/WIPS + SIEM
Rogue AP exposure	High	Unauthorized wireless access	Rogue AP detection
Inadequate payment-data protection	Critical	Cardholder data exposure	Encryption + tokenization
Excessive network access	High	Lateral movement	Least privilege
Weak vulnerability management	High	Known vulnerabilities remain exploitable	Regular scanning and patching

15. Recommended Secure Architecture

A modern retail network should use the following architecture:



This architecture ensures that compromising one wireless segment does not automatically provide access to payment-card systems.

16. Suggested Kali Linux Practical Commands

The following commands can be used in an authorized laboratory to demonstrate the assessment:

Step 1 – Identify network interfaces

```
ip addr
```

Step 2 – Identify wireless interfaces

```
iw dev
```

Step 3 – Check wireless configuration

```
iwconfig
```

Step 4 – Discover nearby Wi-Fi networks

```
nmcli device wifi list
```

Step 5 – Check local routing

```
ip route
```

Step 6 – Discover authorized lab hosts

```
sudo nmap -sn 192.168.1.0/24
```

Step 7 – Enumerate services on an authorized host

```
nmap -sV 192.168.1.10
```

Step 8 – Check listening services

```
sudo ss -tulnp
```

Step 9 – Capture traffic for authorized analysis

```
sudo tcpdump -i wlan0 -w wireless_capture.pcap
```

Step 10 – Analyze the capture

Open the .pcap file in Wireshark:

```
wireshark wireless_capture.pcap
```

These commands are intended for an isolated/authorized laboratory environment and should not be used to test networks without permission.

17. Findings

The assessment indicates that the security weaknesses demonstrated by the TJX incident can be grouped into five major categories:

1. Wireless Encryption:

WEP was inadequate for protecting sensitive corporate communications.

2. Authentication:

Weak wireless authentication increased the possibility of unauthorized access.

3. Network Segmentation:

Insufficient isolation could allow a wireless compromise to become a broader internal-network compromise.

4. Monitoring:

Inadequate wireless and network monitoring could delay identification of unauthorized activity.

5. Payment-Data Protection:

Sensitive payment information requires strong access control, encryption, monitoring, and segmentation.

18. Recommendations

The organization should:

1. Completely eliminate WEP.
2. Deploy WPA2-Enterprise or preferably WPA3-Enterprise.
3. Implement 802.1X with RADIUS.
4. Use certificate-based authentication where practical.
5. Separate guest, employee, IoT, and payment networks.
6. Place payment systems inside a restricted CDE.
7. Implement firewall rules and ACLs between VLANs.
8. Deploy WIDS/WIPS for wireless monitoring.
9. Maintain an inventory of authorized access points.
10. Implement centralized logging and SIEM monitoring.
11. Encrypt sensitive payment data.
12. Minimize storage of payment-card information.
13. Apply PCI DSS controls.
14. Perform regular vulnerability assessments and penetration tests.
15. Follow least-privilege access principles.

16. Continuously monitor for suspicious network activity.

19. Conclusion

The TJX Companies breach demonstrates how weaknesses in wireless security can develop into a large-scale compromise when encryption, authentication, segmentation, monitoring, and payment-data protection are not properly implemented.

The use of obsolete WEP encryption significantly increased wireless security risk. A modern security architecture using WPA2/WPA3-Enterprise, 802.1X authentication, network segmentation, WIDS/WIPS, centralized monitoring, and PCI DSS controls would significantly reduce the likelihood and impact of such an attack.

The most important lesson from the incident is that wireless security should not be treated independently from the rest of the enterprise network. Wireless networks must be considered part of the overall security architecture and must be isolated from critical payment systems through strong authentication, access controls, monitoring, and segmentation.